

SRX TOKEN

Consolidated Internal Security Audit Report

Seven Internal Audit Rounds — Prepared for External Audit Engagement

Project: Syrax Token (SRX)
Repository: Syrax-Global/srx-token (private)
Audit Period: 19 May 2026 – 16 July 2026
Document Date: 16 July 2026
Classification: Confidential
Contact: security@syrax.global

This document consolidates the findings, remediations, and verification evidence of seven internal security audit rounds performed on the SRX Token smart contract suite. It is provided to accelerate and inform the scope of an independent external audit engagement.

Executive Summary

The SRX Token smart contract suite — 15 production contracts, approximately 5,900 lines of Solidity — has undergone seven internal security audit rounds between 19 May 2026 and 16 July 2026. This document consolidates all seven rounds into a single record for external audit reference.

The audit methodology applies seven mandatory review perspectives in every round, aligned with the review disciplines used by leading smart-contract audit firms: (1) code correctness, (2) economic/MEV and cross-contract attack modeling, (3) token invariant verification, (4) upgradeability and storage-layout integrity, (5) cross-chain bridge security, (6) operational stress and external-dependency failure modes, and (7) centralization/trust mapping. Rounds 4, 5 and 7 were each conducted by a reviewer independent of the team responsible for the preceding round, specifically to reduce reviewer-lineage bias.

Convergence, Then Drift

Rounds 1 through 3 (23 May 2026) surfaced the bulk of code-correctness and economic findings — 24 in total, with zero Critical or High severity items persisting after fixes. Round 4 (29 May 2026, an independent reviewer pass) surfaced two governance-topology findings rated High — both architectural rather than code defects — and both were remediated the same day via a dedicated Timelock-only upgrade role and an automated on-chain verification gate. Round 5 (12 June 2026, a second independent pass explicitly targeting the Round 4 remediation code) found zero new Critical, High, or Medium findings. Round 6 (21 June 2026) extended scope beyond contract code to the surrounding deployment, operational, and organizational attack surface.

Round 7 (16 July 2026) is the most instructive round in the programme, and is reported here in full rather than summarised. After the six-round convergence, a change to the staking fee-tier and fee-floor logic was committed on 15 July — after every prior round had signed off. An independent seventh pass, scoped deliberately at post-sign-off code changes and at cross-contract composition, identified three Medium findings in that newly introduced surface. All were remediated and regression-tested.

The programme's conclusion is therefore not simply that the code converged, but something more useful to an incoming auditor: convergence is a property of a frozen codebase, and it does not survive change. The two mechanisms that caught the Round 7 issues — independent review of newly written code, and validating cross-contract composition rather than contracts in isolation — are the two areas where independent external scrutiny is most valuable.

Summary — All Rounds

Round	Date	Findings	Crit / High Open	Status
R1	19 May 2026	6 (5 Low, 1 Info)	0 / 0	Resolved
R2	23 May 2026	8 (1 High*, 3 Med, 2 Low, 2 Info)	0 / 0	Resolved
R3	23 May 2026	11 (1 Med, 6 Low, 4 Info)	0 / 0	Resolved
R4	29 May 2026	11 (2 High, 3 Med, 4 Low, 2 Info)	0 / 2 → 0	Resolved same day
R5	12 Jun 2026	7 (4 Low, 3 Info)	0 / 0	Resolved, regression-tested
R6	21 Jun 2026	1 critical process gap + 11 domain findings	0 / 0 (code)	Highest item remediated
R7	16 Jul 2026	6 (3 Med, 1 Low, 2 Info)	0 / 0	Resolved, regression-tested

** SC-PR-002 (Round 2) was rated High under the single-EOA testnet admin model in effect at the time; it downgrades to Informational once the documented multisig-and-Timelock requirement is in place — a tracked mainnet precondition.*

Verification Coverage

- 692 Hardhat unit/integration tests (1 pending), covering every contract function and access-control path.

- 7 Foundry test suites: 4 system invariants + 3 property-fuzz tests, executing 51,200+ randomized calls with zero reverts. Invariants verified: total-supply conservation, sum-of-balances equals total supply, voting power never exceeds supply, burned amount never exceeds max supply.
- Slither static analysis integrated into continuous integration (build fails on High-severity findings).
- Echidna property-based fuzzing configured for nightly campaigns.
- Every fix across all seven rounds is accompanied by a targeted regression test proving the specific vulnerability class is closed, not merely that the general suite still passes.

External Audit Readiness

The contract suite is assessed as ready for external audit engagement. All contract-code Critical, High, and Medium findings across seven rounds have been resolved and regression-tested. The security team does not consider this internal programme a substitute for an independent external audit: successive internal rounds share process and tooling assumptions that only an external, differently-resourced team can fully escape — and Round 7 demonstrates concretely that a codebase which has converged can still regress when it changes. This document exists to make the external engagement faster, cheaper, and more precisely targeted.

Section 11 ("Focus Areas Requested for External Review") identifies the specific areas where independent scrutiny is most valued.

1. Scope & Methodology

1.1 Contract Scope

15 production contracts, approximately 5,900 lines of Solidity (compiler 0.8.24, vialR pipeline, optimizer at 200 runs, EVM target Cancun). Full contract-by-contract scope, line counts, and complexity notes are provided in the companion document AUDIT_SCOPE.md.

1.2 The Seven Mandatory Review Perspectives

Every round applied — and every round's closing report explicitly accounted for — the following seven perspectives. A perspective producing zero findings in a given round is recorded as verified clean, never silently omitted:

- Code correctness — defensive bug-hunting: off-by-one errors, missing guards, incorrect operators, dead code, input validation.
- Economic / MEV / cross-contract — sandwich attacks, oracle-timing arbitrage, tier-boundary gaming, and composition attacks where each contract is locally safe but the combination is not.
- Token invariant verification — proof-by-inspection of supply conservation, reward-pool solvency, and voting-power conservation across every state-changing function.
- Upgradeability / storage-layout integrity — UUPS proxy safety: initializer protection, storage-gap discipline, upgrade-authorization topology.
- Cross-chain bridge security — endpoint trust, peer authorization, mint/burn conservation across chains, replay protection.
- Operational stress / external dependencies — oracle failure modes, stablecoin depeg, feed staleness, gas-price stress on batch operations.
- Centralization / trust mapping — a complete role-by-role, contract-by-contract matrix of every privileged capability and its compromise impact (a standing deliverable; see Section 9).

1.3 Independent Re-Review Design

Rounds 4, 5 and 7 were each conducted by a reviewer independent of the team responsible for the preceding rounds. Round 5 was scoped to treat all Round 4 remediation code as primary — rather than assumed-safe — attack surface. Round 7 applied the same principle to a code change that landed after every prior round had closed. This constitutes an internal second-opinion review and is the basis for the convergence-then-drift pattern described in the Executive Summary.

2. Round 1 — New-Code Correctness Review (19 May 2026)

Scope: four features added 21–23 May 2026 on top of an already-reviewed 13-contract base (Launch Protection in SRXToken, the new BuybackBurner contract, the new SRXAirdrop contract, and a new rescueTokens admin function). 634 tests passing at time of review.

ID	Title	Sev	Status
SC-LP-001	Self-transfer incorrectly blocked by wallet-cap check	Low	Fixed
SC-BB-001	buyAndBurnWithToken() lacked nonReentrant (defense in depth)	Low	Fixed
SC-BB-002	ETH sent to BuybackBurner had no recovery path	Low	Fixed
SC-AD-001	Airdrop Merkle leaves used single-hash, not the standard double-hash	Low	Fixed
SC-RT-001	rescueTokens() could not recover SRX mistakenly sent to the token contract	Low	Fixed
SC-LP-002	Governance can silently de-exempt a live contract mid-operation	Informational	Documented

3. Round 2 — Economic / MEV / Cross-Contract Review (23 May 2026)

A full re-pass of the suite through an adversarial economic and cross-contract lens — the perspective most likely to surface exploitable dynamics that a pure code-correctness read misses.

ID	Title	Sev	Status
SC-PR-002	PreSaleRound admin could drain investor funds before vault deployment	High	Mitigated — multisig + Timelock required at mainnet
SC-LP-003	Launch protection could block large vesting unlocks without exemption	Medium	Resolved — cap-sizing policy + exemption checklist
SC-PR-001	Oracle staleness window enabled ETH/BTC price-drift arbitrage	Medium	Fixed — staleness window reduced, later per-feed
SC-AD-002	Airdrop Merkle root reuse across chains enabled double-claim replay	Medium	Fixed — chain ID bound into leaf encoding
SC-BB-003	Swap-and-burn flow vulnerable to public-mempool sandwich attacks	Low	Mitigated — private-mempool submission required
SC-VV-001	VestingVault.revoke() could stall if beneficiary is at launch cap	Low	Resolved — vault addresses exempt by policy
SC-BR-001	Cross-chain buyAndBurn reduces global, not chain-local, supply	Informational	Documented
SC-PR-003	Tier-boundary retroactive bonus upgrade is intentional design	Informational	Documented for auditor briefing

4. Round 3 — Invariants, Upgradeability, Bridge, Trust Map (23 May 2026)

Completed the seven-perspective methodology by covering the four perspectives Rounds 1 and 2 had not yet exercised. Produced the first version of the Centralization Trust Matrix (see Section 9).

ID	Title	Sev	Status
SC-OPS-001	Oracle price accepted with no plausibility bounds	Medium	Fixed — min/max price bounds added
SC-UUPS-001	No documented storage-gap discipline for future upgrades	Low	Fixed — NatSpec discipline + runbook requirement
SC-UUPS-002	Initializer granted roles before all state was set	Low	Fixed — state-before-roles ordering enforced

SC-LZ-001	Bridge setPeer is owner-gated with no Timelock delay	Low	Mitigated — pause guard added; carried to R4/R6
SC-OPS-002	USDC/USDT hardcoded at \$1 with no depeg protection	Low	Fixed — optional Chainlink stablecoin feed added
SC-OPS-003	ETH withdrawal to a non-payable address had no partial option	Low	Fixed — partial-withdraw variant added
SC-OPS-004	Permit-deadline timing sensitivity (protocol-wide EIP limitation)	Low	Documented — integration guidance issued
SC-INV-001/2/3	Supply, voting-power, and reward invariants verified by inspection	Informational	Verified clean

5. Round 4 — Independent Full Re-Pass (29 May 2026)

An independent reviewer pass across all seven perspectives against the complete suite, verifying Rounds 1–3 fixes were present and hunting new ground. Central finding: code-level security was strong, but the deployment-time role topology was off-chain and unenforced — the security narrative in the contract documentation was only true after a precise, unenforced post-deployment migration.

ID	Title	Sev	Status
SC-TRUST-001	Upgrade authority gated on the same multipurpose role the admin held, not the Timelock	High	Fixed same day — dedicated Timelock-only upgrade role
SC-TRUST-002	Privileged roles concentrated on the deployer address, no enforced migration	High	Fixed same day — automated verification gate added
SC-LZ-001	(Carried forward) Bridge peer-set authority not Timelock-gated	Medium	Documented as a deployment gate pre-mainnet
SC-TRUST-003	Emergency fast-path deployment had no destination allowlist	Medium	Fixed — governance-managed allowlist added
SC-TRUST-004	PreSaleRound admin could sweep funds / revoke vaults unilaterally	Medium	Documented — admin must be a multisig
SC-ECON-001	Reward-pool emission not bounded by the funded pool	Low	Fixed — emission capped to funded pool
SC-ECON-002	Single staleness threshold did not fit multiple feed heartbeats	Low	Fixed — per-feed staleness overrides added
SC-OPS-001	Stablecoin oracle feed lacked price-bound checks	Low	Fixed — bounds parity with ETH/BTC feeds
SC-CR-001	Contract documentation described the wrong leaf encoding	Low	Fixed — documentation corrected

6. Round 5 — Independent Adversarial Re-Pass (12 June 2026)

A reviewer independent of the Round 4 team re-audited the full suite, explicitly treating all Round 4 remediation code as primary attack surface. Result: zero new Critical, High, or Medium findings.

ID	Title	Sev	Status
R5-01	Stranded reward-pool recovery applied to one contract but not its structural twin	Low	Fixed — matching recovery + regression tests
R5-02	Mid-round price change could interact unsafely with top-up accounting	Low	Fixed — price locked once first investor recorded
R5-03	Allocation-correction function omitted a bonus factor used elsewhere	Low	Fixed — corrected inverse, round-trip verified
R5-04	A read-only quote function used a different pricing path than live investment	Low	Fixed — quote path matches live path
R5-05/06/07	Minor rounding dust; standard bridge behavior; input-validation reminder	Informational	Documented / subsumed

7. Round 6 — Holistic Systemic Threat Model (21 June 2026)

Round 6 audited what contract-code rounds structurally could not reach: deployment process, key custody, economic design, bridge configuration, governance mechanics, oracle infrastructure, supply-chain integrity, regulatory posture, post-launch operations, formal-verification coverage, and incident-response realism — twelve domains.

The review found the genesis token-generation-event execution — which moves the full 10-billion-token supply to its destination addresses — relied on manually configured environment values with no automated destination allowlist. A single misconfigured address could have sent an unrecoverable share of total supply to the wrong destination. This was the most severe finding of the programme and was remediated within the same round.

Finding	Domain	Sev	Status
No automated destination allowlist for token-generation-event distribution	Deployment	Critical	Remediated — automated pre-flight verification now gates execution
Mainnet deployment signing relies on a single raw private key	Deployment	High	Documented — hardware-wallet procedure specified
A legacy migration script could be run by mistake, re-opening a resolved issue	Deployment	High	Deprecated in favor of the verified tool
No documented sell-pressure model for vesting unlock cliffs	Economic design	High	Drafted — requires founder input
Bridge verifier-set configuration not yet a specified deployment gate	Bridge	High	Drafted — requires a verifier-set decision
Multisig custody ceremony not yet documented	Key management	High	Drafted — requires founder finalization
Further findings across oracle config, build integrity, governance timeline, regulatory mapping, launch operations, formal verification, incident response	6 further domains	Med/Low	Documented remediation backlog

8. Round 7 — Post-Change Independent Re-Pass (16 July 2026)

On 15 July 2026 — after all six prior rounds had closed — a change was committed to the staking fee-tier and fee-floor logic, addressing two commercial concerns: that the top fee-discount tier implied a permanently zero platform fee, and that the tier could be obtained with no genuine duration commitment. Both concerns were legitimate. The change itself, however, had not been reviewed by any audit round, and its own commit message recorded that the Foundry suite had not been executed against it.

Round 7 was scoped accordingly: newly introduced post-sign-off code, plus cross-contract composition — the two surfaces a converged, per-contract review programme is least able to cover. It produced three Medium findings, all in code introduced after Round 6, and all since remediated with dedicated regression tests.

ID	Title	Sev	Status
R7-01	Fee tier persisted indefinitely after lock expiry — the duration multiplier granted a permanent entitlement for a finite commitment, halving the capital cost of the top tier	Medium	Fixed — multiplier now applies only while the lock is active; reverts to raw principal at expiry
R7-02	Guardian pause-state desynchronisation could revert the entire emergency stop, disabling it for every module	Medium	Fixed — batch pause/unpause made best-effort per module, with state reconciliation and events
R7-06	The pausable test double could not revert, so the guardian test suite could not detect the failure class in R7-02	Medium	Fixed — faithful test double added implementing real pause semantics
R7-03	Fee-floor could be configured above the base fee, inverting discounts into increases	Low	Fixed — invariant enforced across all three setters
R7-04	Scope changed after audit sign-off; Foundry suite unverified against the change	Informational	Resolved — Foundry executed and passing; branch freeze recommended
R7-05	Public tier documentation does not yet reflect duration weighting	Informational	Flagged for update before public launch

Two observations from this round are worth surfacing to an incoming auditor.

First, R7-02 existed only in the composition of the guardian module's locally tracked state with six external contracts, each exposing an independent pause authority. No single file was incorrect. Reviews that proceed contract-by-contract are structurally unable to detect this class of issue.

Second, R7-06 explains why R7-02 survived six rounds: the pausable test double used throughout the guardian test suite implemented pause as an unguarded boolean assignment, so it could never revert. Every scenario depending on real pause semantics passed trivially. Test doubles that diverge from production behaviour are more dangerous than absent tests, because they produce confidence in an unexercised path. The suite has been given a faithful double; migrating the remaining guardian tests to it is recommended.

A product decision is embedded in the R7-01 remediation and is flagged explicitly rather than left implicit: a staker who reached a tier via a long lock now returns to the tier their raw principal earns once that lock expires, restorable by re-locking. This treats the duration multiplier as pricing active commitment. If permanent tiers are instead intended, the thresholds require re-derivation, because under the prior behaviour the top tier's effective cost was half its nominal value.

9. Centralization / Trust Matrix

Produced as a standing deliverable under Perspective 7 and maintained across rounds. This is the authoritative map of every privileged capability in the system, its intended holder, and the impact of its compromise.

Contract	Role	Intended Holder (Mainnet)	Compromise Impact
SRXToken	Admin / Governance / Pauser	Multisig → Timelock / Guardian module	Total token control if unmigrated; mitigated post-migration
SRXToken	Bridge owner (setPeer)	Timelock, or a hardened multisig	Cross-chain mint-without-burn if compromised
Treasury / Staking / Fee / Stabilisation	Upgrade authority	Timelock only, dedicated role	Fund drain via malicious upgrade if misconfigured; closed by dedicated role + gate
StabilisationFund	Emergency fast-path deployment	Distinct treasurer / guardian multisigs, allowlisted	Bounded drain per stress cycle if a signer is compromised
PreSaleRound	Round administrator	Multisig (mainnet requirement)	Investor funds at discretion until vault deployment — disclosed
Guardian module	Guardian / governance override	Guardian multisig / Timelock	Time-bounded pause only; governance can always override

Round 7 note: pause authority is currently held by both the guardian module and the admin multisig on every pausable contract. Consolidating it to the guardian module alone post-migration removes the desynchronisation source behind R7-02 at its root; the code is now tolerant of the condition either way.

10. Seven-Perspective Coverage Confirmation

No round is considered complete without an explicit accounting of all seven perspectives — a perspective producing zero findings is recorded as verified clean, never silently omitted.

Perspective	Rounds	Cumulative Result
1. Code correctness	R1, R4, R5, R7	All findings resolved and regression-tested
2. Economic / MEV / cross-contract	R2, R4, R5, R7	All resolved; R7 closed a fee-tier economic leak in newly added code
3. Invariant verification	R3, R4, R5, Foundry	Verified clean every round; 51,200+ randomized calls, zero reverts
4. Upgradeability / storage	R3, R4, R5	Storage-gap discipline enforced; upgrade authority isolated to a Timelock-only role
5. Cross-chain bridge	R3, R4, R5, R6	Core bridge logic verified against its audited upstream base; verifier-set configuration tracked as a deployment gate
6. Operational stress / external deps	R3, R4, R5, R7	Oracle and depeg protections tested; R7 hardened the emergency-pause path
7. Centralization / trust map	R3, R4, R5, R6, R7	Full matrix maintained; role migration mechanically enforced by automated tooling

11. Focus Areas Requested for External Review

The following areas are proactively flagged as where independent, differently-tooled scrutiny is most valued — not because internal review found unresolved issues, but because these are the highest-leverage areas for a second, independent opinion:

- The cross-chain bridge — mint/burn conservation, peer-authorization topology, and decentralized-verifier-network configuration.
- The Timelock-only upgrade-authority separation introduced in Round 4 — confirmation that the role topology and its automated verification gate correctly close the upgrade-authority risk.
- Cross-contract composition generally, and the guardian module's pause orchestration specifically. Round 7 found that the only Medium-severity composition issue in the suite was invisible to per-contract review; the remediation is new and would benefit from independent confirmation.
- The staking fee-tier and fee-floor logic changed in July 2026 and remediated in Round 7 — the newest code in the suite, and correspondingly the least reviewed.
- Presale contract oracle-pricing and tier-bonus mathematics — the most complex arithmetic in the suite, refined across four rounds.
- The dual reward-accounting systems in the staking and stabilisation-fund contracts — emission-cap correctness under adversarial parameter changes.
- Formal verification of the cross-contract supply-conservation invariant, which internal test coverage currently verifies only at the single-contract level.

12. Contact & Access

Repository access, the current test suite, build instructions, and the full unabridged internal findings for each round are available on request. The audit commit will be tagged at engagement start so the review maps to an immutable tree. The team is available for scoping calls and ongoing questions throughout the engagement.

Security contact: security@syrax.global

Repository: github.com/Syrax-Global/srx-token (private — read access available on request)